MITTUNIVERSITETET
Institutionen för informationsteknologi och medier (ITM)
Examinator: Magnus Eriksson
Författarnas e-postadresser: axsj2400@student.miun.se, omsu2400@student.miun.se
Utbildningsprogram: TDATG Datateknik
Datum: 2025-12-18

Projektrapport inom

DT024G - Datornätverk, 7.5 hp

Intrusion Detection Systems

En jämförelse mellan IDS-systemen Snort och Suricata

vid upptäckt av nätverksattacker

Omar Sultanzoy & Axel Sjögren

Sammanfattning

Vilket IDS-system upptäcker flest attacker? Vilket ger mest träffsäkra larm? Denna studie har gjorts för att svara på dessa frågor genom att jämföra de två IDS-systemen Snort och Suricata. Våran studie jämför Snort och Suricata genom att testa deras förmåga att upptäcka både aggressiva och stealth-portscanningar som gjorts med NMAP. Syftet är att avgöra vilket system som upptäcker flest nätverksattacker.

Denna studie har utförts i en virtuell miljö med hjälp av Oracle VirtualBox. Snort detekterade båda typerna av scanningar, aggressiv och stealth, vilket innebär hög recall men lägre precision. Suricata detekterade endast den aggressiva scanningen, vilket ger hög precision men lägre recall.

Avslutningsvis kan man inte säga att det ena systemet är generellt bättre än det andra. Båda har sina för- och nackdelar beroende på vilken situation man är i. Snort passar bäst i miljöer där det är kritiskt att man fångar upp all farlig aktivitet, oavsett storlek på attacken och att man kommer få fler false alarms. Suricata passar bäst i miljöer där man vill ha den körandes i bakgrunden för att skydda mot större nätverksattacker.

Innehållsförteckning

Sammanfattning **1**
1 Inledning **3**
2 Teori **4**
2.1 IDS-system 4
2.2 Snort 4
2.3 Suricata 5
2.4 Utvärderingsmått 5
2.4.1 True Positive (TP) 5
2.4.2 True Negative (TN) 5
2.4.3 False Positive (FP) 5
2.4.4 False Negative (FN) 6
2.4.5 Precision & Recall 6
3 Metod **7**
4 Resultat **8**
4.1 Snort Test 1 - Aggressiv 8
4.2 Snort Test 2 - Icke aggressiv 9
4.3 Suricata Test 1 - Aggressiv 10
4.4 Suricata Test 2 - Icke-aggressiv 12
4.5 Jämförelse mellan Snort och Suricata 12
5 Slutsats **13**
Källförteckning **14**

1 Inledning

Internet har blivit en allt större och större faktor av våra liv i samband med teknikens exponentiella utveckling. Detta har givit upphov till stor press och krav på nätverk världen över. Vare sig hemma, på jobbet eller på stora företag såsom Microsoft, behöver säkerheten vara på topp. Många stora företag blir otroligt sårbara för nätverksattacker om de inte har någon typ av IDS-system. De två systemen som kommer att jämföras i denna studie är ett enklare mot ett mer omfattande IDS-system.

Syftet med denna studie är att ta reda på vad som skiljer de två systemen åt när de blir utsatta för en iscensatt nätverksattack. Vilket IDS-system upptäcker flest attacker? Vilket ger mest träffsäkra larm? Detta är frågor som kommer att besvaras senare i denna studie för att underlätta valet av IDS-system ur ett nätverksperspektiv.

De två IDS-systemen som jämförs är Snort och Suricata. De har jämförts i hur de reagerar på två olika typer av Nmap-scans, en aggressiv och en icke-aggressiv stealth-scan, samt hur många larm som de genererar. Vilka typer av avvikelser de rapporterar och hur träffsäkra dessa larm är när det gäller att upptäcka potentiella hot.

I denna rapport presenteras undersökningsmetod följt av resultat och slutsats.

2 Teori

I detta avsnitt förklaras de viktigaste teorierna bakom intrångsdetektion. Vi går bland annat igenom hur IDS-system fungerar och vilka begrepp som används för att utvärdera träffsäkerhet.

2.1 IDS-system

Ett *intrångsdetekteringssystem* (IDS) är ett nätverkssäkerhetsverktyg som övervakar enheter och nätverkstrafik för skadlig aktivitet, misstänkt aktivitet eller brott mot säkerhetspolicyer. Ett IDS kan alltså inte stoppa själva attackerna i sig, utan fungerar främst för att varna, generera larm till säkerhetsadministratörer eller vidarebefordra händelser till ett centralt övervakningssystem. [1] De två huvudsakliga metoder som IDS använder för att upptäcka hot är *signaturbaserad* och *anomalibaserad* detektion. Signaturbaserade jämför nätverkstrafik mot en databas av kända attacksignaturer och larmar när en match hittas. Anomalibaserade skapar en modell av ett normalt nätverksbeteende och flaggar trafik som avviker från det normala mönstret, vilket kan leda till fler falsklarm men också avslöja helt nya angrepp.

2.2 Snort

Snort började som ett enkelt verktyg för att snappa upp nätverkstrafik men har under många år utvecklats till ett avancerat IDS-system. Projektet startades av Martin Roesch i slutet av 1990-talet och vidareutvecklades senare av företaget Sourcefire. När Cisco köpte Sourcefire blev Snort en del av deras säkerhetslösningar. [2] Snort fungerar genom att läsa av nätverkspaket och jämföra dem med ett regelverk som beskriver hur olika attacker möjligtvis skulle kunnat se ut. Först tolkas paketen, sedan bearbetas de av olika ”preprocessors” som känner igen protokoll eller normaliserar datan och till sist analyseras allt av den motor som matchar reglerna. Om någon avvikelse upptäcks eller att det blir en match med en redan definierad attack, kan Snort larma vidare eller skapa loggar.

2.3 Suricata

Suricata är ett öppet IDS-system som är utvecklat med fokus på hög prestanda och modern trafikhantering. Systemet har byggts vidare under många år och är från början anpassat för att kunna dra nytta av flera processorkärnor samtidigt, vilket gör att det klarar större mängder nätverkstrafik utan att tappa hastighet. Suricata används både i företag, offentliga organisationer och av olika molnleverantörer, antingen som fristående lösning eller integrerat i andra säkerhetsprodukter. [3] En av styrkorna med Suricata är att det kan köras i flera olika lägen beroende på vad man vill uppnå. I sitt vanliga IDS-läge genererar det larm baserat på regler och andra indikatorer, medan IPS-läget gör det möjligt att aktivt stoppa trafik som bedöms som skadlig. Det finns även ett renodlat övervakningsläge där systemet loggar all trafik och protokollinformation utan att jämföra mot signaturer, samt alternativ där det sparar inspelade paketflöden som PCAP-filer.

2.4 Utvärderingsmått

För att avgöra om ett IDS-system är effektivt finns det mätvärden som beskriver om larmen är korrekta eller inte. Nedan följer de grundläggande koncept som vanligtvis används för att utvärdera noggrannhet.

2.4.1 True Positive (TP)

Ett *true positive* uppstår när IDS-systemet larmar om en händelse som faktiskt är ett intrång. Det betyder att systemet har fungerat som det ska och gjort en korrekt bedömning. Exempel på detta kan vara att en portskanning med Nmap upptäcks och markeras som misstänkt trafik. [4]

2.4.2 True Negative (TN)

Ett *true negative* uppstår när systemet korrekt bedömer något som ofarligt i en situation där det faktiskt inte finns något hot. Det kan exempelvis handla om att ofarlig trafik förbises eller att en sårbarhetsskanning inte hittar några brister i programvara som faktiskt är säker [5]

2.4.3 False Positive (FP)

Ett false positive innebär att ett säkerhetsverktyg felaktigt markerar något som ett hot, trots att trafiken eller funktionen egentligen är helt normal. Det kan handla om att ett IDS eller en brandvägg tror att en sårbarhet finns, men i verkligheten fungerar allt som det ska. Falsklarm kan bli tidskrävande att utreda och tar ofta resurser från annat arbete. [6]

2.4.4 False Negative (FN)

Ett *false negative* innebär att ett problem finns, men att systemet inte upptäcker det. I ett IDS-sammanhang betyder det att en attack faktiskt sker, men att inget larm genereras eller skickas vidare. False negatives är allvarliga eftersom de döljer verkliga hot. När misstänkt aktivitet inte fångas upp kan intrånget fortsätta obemärkt, vilket gör att skadorna kan bli större. [7]

2.4.5 Precision & Recall

Precision beskriver hur stor andel av de larm som genereras som faktiskt är korrekta, alltså andelen *true positives* av alla larm (true positives + false positives). *Recall* beskriver istället hur stor andel av alla verkliga intrång som systemet lyckas upptäcka, det vill säga andelen *true positives* av alla verkliga intrång (true positives + false negatives). Högt värde på precision innebär få falsklarm, medan högt recall betyder att få attacker missas. [8]

$$\text{Precision} = \frac{tp}{tp + fp}$$

$$\text{Recall} = \frac{tp}{tp + fn}$$

3 Metod

Undersökningen har genomförts med hjälp av en litteraturstudie av ett antal webbsidor. Det har gett användbar information inom olika former av intrångsdetektering och hur IDS-system skiljer sig åt i både uppbyggnad och funktioner.

Programmet Oracle VirtualBox har använts för att installera två virtuella maskiner som har simulerat två användarmiljöer, en som attackerar och en som försvarar. Till de virtuella maskinerna har vi allokerat 3GB fysiskt minne (RAM) och 3 logiska processorer. Båda maskinerna har körts lokalt på en laptop.

Programmet Snort har använts för att analysera och övervaka inkommande trafik på VM1 samt logga eventuella intrångsförsök. Snort startades i terminalen med standardkonfiguration och kördes i realtid för att upptäcka avvikande trafikmönster under testerna.

Programmet Suricata har använts för att logga nätverkstrafik och generera alerts baserat på dess signaturer. Trafiken analyserades genom Suricatas loggfil eve.json, där endast larm filtrerades ut med hjälp av grep för att få en tydlig översikt över upptäckta händelser.

För att simulera attacker installerades Nmap på VM2. Nmap användes för att utföra portscanningar mot VM1:

- En aggressiv scanning med kommandot *sudo nmap -sS -A 192.168.10.10*, som både utför portscanning och kör skript som försöker samla in detaljerad information.
- En icke-aggressiv stealth-scan med kommandot *sudo nmap -sS 192.168.10.10*, där syftet är att minimera mängden paket och undvika upptäckt.

Resultaten från Snort och Suricata analyserades genom att räkna antal larm, kategorisera identifierade attacker och jämföra systemen utifrån begrepp såsom precision och recall för att bedöma deras träffsäkerhet.

4 Resultat

4.1 Snort Test 1 - Aggressiv

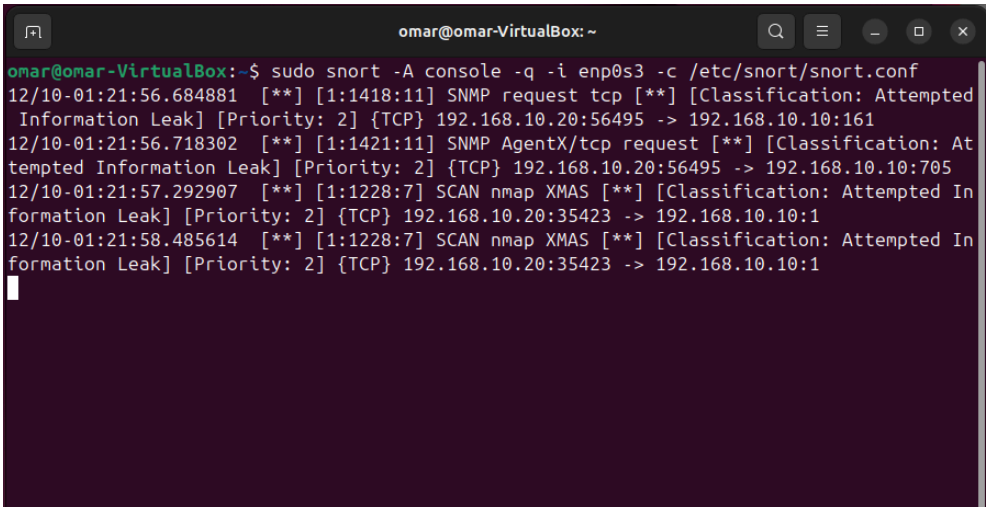
Resultat av kommando: sudo nmap -sS -A 192.168.10.10

Det kommandot gör är att det skickas en stor mängd paket med hjälp av nmap. Kommandot har parametrar, "-sS", vilket innebär att den skickar SYN-packets till target för att identifiera koppling mellan host och target IP.

Analys av output i terminalen: "*SNMP request tcp & SNMP AgentX/tcp request*" har klassificering: Attempted Information Leak. Detta betyder att när vi körde -A som parameter till kommandot så exekverade nmap skripter för att försöka få tag på så mycket information om target IP som möjligt. En av dessa är snmp-info som försöker hämta information via SNMP (Simple Network Management Protocol). Detta är en indikation på True Positive (TP). Sammanfattning av ovan: Snort detekterade att nmap försökte samla information om IP 192.168.10.10 via SNMP.

Snort detekterade även: "SCAN nmap XMAS" som också har klassificering: Attempted Information Leak. Vilket betyder att när vi körde -A som parameter så körde den också skattningsmetoder, i detta fall en XMAS-scan som skickar paket med FIN, URG, och PUSH-flaggor, vilket är en onormal kombination av flaggor, anledning för detta är för att undvika detection men Snort lyckades fånga upp det. Detta är också ett True Positive.

Snort har alltså hittat 4 true positives från detta kommando (se **Figur 1**)



(**Figur 1** - Visar output i terminal från Snort)

Svar som VM2 fick efter kommandot: sudo nmap -sS -A 192.168.10.10

Utifrån detta kunde vi analysera att alla portar är stängda i VM1. Men känner VM1 ändå av fuffens? Ja, Snort kände fortfarande av att någon försökte scanna nätverket. Se **Figur 2** nedan.

```
omar@omar-VirtualBoxVM2:~$ sudo nmap -sS -A 192.168.10.10
[sudo] password for omar:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-10 01:56 CET
Nmap scan report for 192.168.10.10
Host is up (0.0011s latency).
All 1000 scanned ports on 192.168.10.10 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:83:24:0C (Oracle VirtualBox virtual NIC)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

TRACEROUTE
HOP RTT     ADDRESS
1   1.11 ms 192.168.10.10

OS and Service detection performed. Please report any incorrect results at https
://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.16 seconds
omar@omar-VirtualBoxVM2:~$
```

(**Figur 2** - Visar output och resultat i terminal trots att alla portar i VM1 var stängda)

4.2 Snort Test 2 - Icke aggressiv

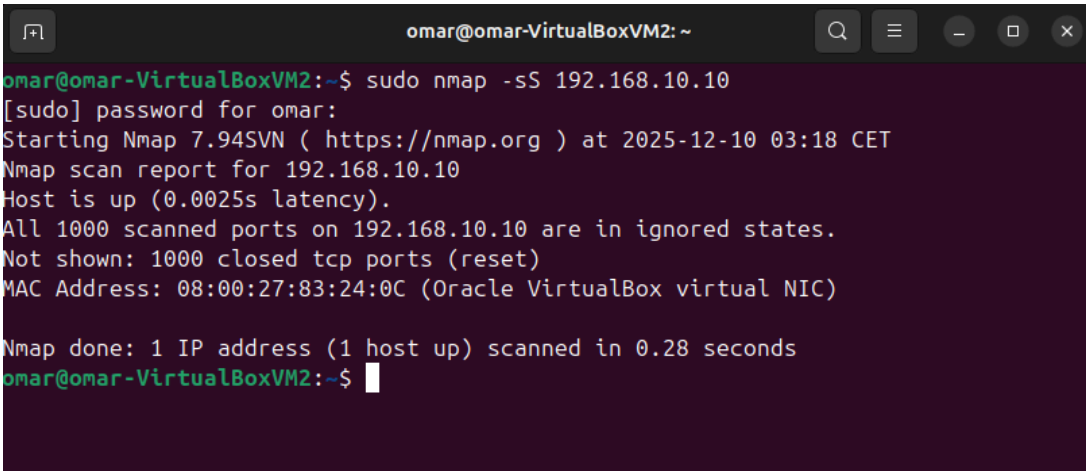
Resultat från Snort med kommando: sudo nmap -sS 192.168.10.10

Nästan exakt samma kommando skickades, denna gång utan "-A". Skillnaden i kommandot är att detta kommando inte gör en aggressiv scan som exekverar skripts m.m, utan en "stealth scan". Målet med detta kommando är att bara få kontakt med taget IP, för att se ifall den är aktiv, vilket den är, och Snort fångade upp att någon försökte scanna portarna. Vi ser från resultatet att den fångade upp SNMP request tcp & SNMP AgentX/tcp request, alltså två TP:n.

```
omar@omar-VirtualBox: ~
omar@omar-VirtualBox:~$ sudo snort -A console -q -i enp0s3 -c /etc/snort/snort.conf
[sudo] password for omar:
12/10-03:18:37.841704  [**] [1:1418:11] SNMP request tcp [**] [Classification: Attempted
 Information Leak] [Priority: 2] {TCP} 192.168.10.20:37215 -> 192.168.10.10:161
12/10-03:18:37.892934  [**] [1:1421:11] SNMP AgentX/tcp request [**] [Classification: At
tempted Information Leak] [Priority: 2] {TCP} 192.168.10.20:37215 -> 192.168.10.10:705
```

(**Figur 3** - Visar output efter stealth scan)

Det hände även samma här, inga portar öppen i VM1:s nätverk men Snort fångade fortfarande upp två scans. Se en sammanställning av Snorts resultat i **Tabell 1**.



(**Figur 4** - Visar output och resultat i terminal trots att alla portar var stängda)

Paremeter	*Aggressiv scan (-sS -A)*	*Icke-aggressiv scan (-sS)*
Antal Snort-larm	4	2
Typ av larm	SNMP + XMAS-scan	Endast SNMP
Scanningstid	2.16 sekunder	0.28 sekunder

(**Tabell 1** - Sammanställning av resultat från Snort)

4.3 Suricata Test 1 - Aggressiv

Resultatet från Suricata kunde avläsas från output efter körning av kommandot:
sudo nmap -sS -A 192.168.10.10

Suricata loggar all nätverkstrafik i en json-fil. Nedan ser vi en mycket filtrerad version av json-filen då den loggade 1048 paket. Filen filtrerades med hjälp av bash kommandot: *sudo grep '"event_type":"alert"' /var/log/suricata/eve.json > alerts.txt*, som filtrerar filen efter strängen '"event_type":"alert"' och omdirigerar datan till en ny textfil.

{"timestamp":"2025-12-10T10:12:52.512857+0100","flow_id":1358282090864756,"in_iface":"enp0s3","event_type":"alert","src_ip":"192.168.10.20","src_port":0,"dest_ip":"192.168.10.10","dest_port":0,"proto":"ICMP","icmp_type":8,"icmp_code":9,"pkt_src":"wire/pcap","alert":{"action":"allowed","gid":1,"signature_id":2200025,"rev":2,"signature":"SURICATA ICMPv4 unknown code","category":"Generic Protocol Command Decode","severity":3},"direction":"to_server","flow":{"pkts_toserver":1,"pkts_toclient":0,"bytes_toserver":162,"bytes_toclient":0,"start":"2025-12-10T10:12:52.512857+0100","src_ip":"192.168.10.20","dest_ip":"192.168.10.10"}}

{"timestamp":"2025-12-10T10:12:52.513075+0100","flow_id":1358282090864756,"in_iface":"enp0s3","event_type":"alert","src_ip":"192.168.10.10","src_port":0,"dest_ip":"192.168.10.20","dest_port":0,"proto":"ICMP","icmp_type":0,"icmp_code":9,"pkt_src":"wire/pcap","alert":{"action":"allowed","gid":1,"signature_id":2200025,"rev":2,"signature":"SURICATA ICMPv4 unknown code","category":"Generic Protocol Command Decode","severity":3},"direction":"to_client","flow":{"pkts_toserver":1,"pkts_toclient":1,"bytes_toserver":162,"bytes_toclient":162,"start":"2025-12-10T10:12:52.512857+0100","src_ip":"192.168.10.20","dest_ip":"192.168.10.10"}}

{"timestamp":"2025-12-10T10:12:53.646988+0100","flow_id":1358282090864756,"in_iface":"enp0s3","event_type":"alert","src_ip":"192.168.10.20","src_port":0,"dest_ip":"192.168.10.10","dest_port":0,"proto":"ICMP","icmp_type":8,"icmp_code":9,"pkt_src":"wire/pcap","alert":{"action":"allowed","gid":1,"signature_id":2200025,"rev":2,"signature":"SURICATA ICMPv4 unknown code","category":"Generic Protocol Command Decode","severity":3},"direction":"to_server","flow":{"pkts_toserver":3,"pkts_toclient":2,"bytes_toserver":516,"bytes_toclient":354,"start":"2025-12-10T10:12:52.512857+0100","src_ip":"192.168.10.20","dest_ip":"192.168.10.10"}}

{"timestamp":"2025-12-10T10:12:53.647014+0100","flow_id":1358282090864756,"in_iface":"enp0s3","event_type":"alert","src_ip":"192.168.10.10","src_port":0,"dest_ip":"192.168.10.20","dest_port":0,"proto":"ICMP","icmp_type":0,"icmp_code":9,"pkt_src":"wire/pcap","alert":{"action":"allowed","gid":1,"signature_id":2200025,"rev":2,"signature":"SURICATA ICMPv4 unknown code","category":"Generic Protocol Command Decode","severity":3},"direction":"to_client","flow":{"pkts_toserver":3,"pkts_toclient":3,"bytes_toserver":516,"bytes_toclient":516,"start":"2025-12-10T10:12:52.512857+0100","src_ip":"192.168.10.20","dest_ip":"192.168.10.10"}}

(**Figur 5** - Filtrerat utdrag från json-filen)

4.4 Suricata Test 2 - Icke-aggressiv

Resultatet från Suricata kunde avläsas från output efter körning av kommandot:
sudo nmap -sS -A 192.168.10.10

Totalt skickades 1005 paket. Filen filtrerades med hjälp av bash kommandot: *sudo grep '"event_type":"alert"' /var/log/suricata/eve.json > alerts.txt*. Resultatet blev tomt. Suricata kände inte av silent-scannen som nmap utförde och gjorde därmed heller ingen åtgärd eller larmning.

Parameter	*Aggressiv scan (-sS -A)*	*Icke-aggressiv scan (-sS)*
Antal Suricata larm	4	-
Typ av larm	ICMP unknown code	-
Scanningstid	1.13 sekunder	-

(**Tabell 2** - Sammanställning av resultat från Suricata)

4.5 Jämförelse mellan Snort och Suricata

Testerna visar tydliga skillnader i hur Snort och Suricata hanterar Nmap-attacker.

Snort genererade larm i båda testerna, både vid aggressiv och icke-aggressiv scanning. Detta innebär att Snort lyckades identifiera nätverksaktivitet som avviker från normalt beteende även när den som attackerar försökte dölja trafiken, exempelvis via en stealth-scan. Snort uppnådde därmed ett högt värde på recall, eftersom få eller inga attacker missades.

Suricata gav däremot ett annat resultat. Vid aggressiv scanning registrerades flera larm, bland annat ICMP-relaterade avvikelser (Figur 5) . Vid icke-aggressiv scanning genererades däremot inga larm alls och loggfilen blev tom. Detta innebär att Suricata hade hög precision, den larmade inte på normal eller lågintensiv trafik, men sämre recall eftersom den missade en faktisk attack.

Sammantaget tyder resultaten på följande:

- **Snort**: hög recall, lägre precision (larmar på fler händelser, även subtila attacker = få attacker missas, men risk för fler FP)
- **Suricata**: hög precision, lägre recall (mer försiktig, färre falsklarm = risk att missa lågintensiva attacker)

Dessa skillnader är viktiga beroende på användningsområde. En organisation eller företag som prioriterar att upptäcka alla intrång kan gynnas av att använda Snort som IDS-system, medan miljöer där för många falsklarm skapar problem kan valet av Suricata vara att föredra.

5 Slutsats

Testerna visar att Snort och Suricata skiljer sig tydligt i hur de identifierar potentiella intrång och behandlar nätverkstrafik. Snort reagerade på både den aggressiva Nmap-scanningen och stealth-scanningen, vilket innebär att systemet har en hög känslighet för avvikande trafik. Detta gör Snort lämpligt i miljöer där det är viktigare att upptäcka så många hot som möjligt, även om det innebär en risk för fler falsklarm.

Suricata flaggade däremot endast vid den aggressiva scanningen och genererade inga larm under stealth-testet. Detta visar på att Suricata i sin grundkonfiguration prioriterar att undvika falsklarm framför att identifiera subtila skanningar. Konsekvensen blir en högre precision men lägre recall, vilket innebär att vissa intrång kan passera obemärkta.

Resultaten bekräftar att inget av systemen är överlägset ”bättre” i alla scenarier. Båda systemen har olika styrkor och bör av den anledningen matchas mot verksamhetens krav. Om målet är att försöka upptäcka så många intrång som möjligt är Snort det självklara valet. Om man istället vill minimera mängden falsklarm och fokusera på tydliga attackmönster kan Suricata vara alternativet att föredra. Studien visar därmed att valet av IDS bör baseras på vilken balans mellan noggrannhet och känslighet som är mest relevant för den aktuella miljön den ska verka på.

Källförteckning

[1] IBM, *What is an intrusion detection system (IDS)?*, https://www.ibm.com/think/topics/intrusion-detection-system, Hämtad: 2025-12-09

[2] Wiki Linux, *Snort*, https://wiki.linux.se/index.php/Snort, Hämtad: 2025-12-09

[3] Suricata, *What is Suricata*, https://suricata.io/2024/04/15/what-is-suricata/, Hämtad: 2025-12-09

[4] Cycognito, *True Positive,* https://www.cycognito.com/glossary/true-positive.php, Hämtad: 2025-12-09

[5] Cycognito, *True Negative,* https://www.cycognito.com/glossary/true-negative.php, Hämtad: 2025-12-09

[6] Contrast Security, *What is false positive in cybersecurity?*, https://www.contrastsecurity.com/glossary/false-positive, Hämtad: 2025-12-09

[7] Contrast Security, *What is a false negative?*, https://www.contrastsecurity.com/glossary/false-negative, Hämtad: 2025-12-09

[8] Wikipedia, *Precision and recall*, https://en.wikipedia.org/wiki/Precision_and_recall, Hämtad: 2025-12-09